Research.gov - Proposal Review Page

research.gov/gapps-web/gapps/viewApplicationReview

Agency Name:

National Science Foundation

Agency Tracking Number:

2533187

Organization:

Translational Impacts

NSF Program:

SafeOSE

PI/PD:

Millman, Kenneth

Application Title:

NSF Safe-OSE: Securing the Scientific Python Ecosystem

Rating:

Good

Review

Summary

Proposal Synopsis

This proposal is to enhance the security of the Scientific Python Open Source Ecosystem (SP-OSE) through the creation of a developer reputation system, a federated vulnerability management system, and automated anomaly detection.

Intellectual Merit
Strengths
+SP-OSE is a widely used open-source system benefiting many researchers from various disciplines in the world

+Scientific Python Project (SPP) founded by the PIs has attracted many users and contributors on different platforms

+The existing security vulnerabilities identified are important

+The presented evaluation plan is solid

Weaknesses
-While the team has extensive experience in software development and open-source platforms, none of the team members seems to have any experience in security

-Related to above, the proposed security enhancement work needs to be described in more detail

-There is no separate Intellectual Merit section in the project description

Broader Impacts
Strengths
+Addressing these security vulnerabilities in SP-OSE will pose impacts in scientific research, education, and economy, as well as national security

+The open-source community will be able to leverage experiences gained from this project to benefit other open-source platforms

Weaknesses
-None observed

Additional Solicitation-specific Review Criteria
Strengths & Weaknesses

> **Does the proposal present a convincing case that the targeted OSE addresses an issue of significant societal or national importance?**

Yes. The SP-OSE is widely used by researchers all over the world.

> **Does the proposal clearly describe the vulnerability landscape for the OSE and its product(s)?**

Yes. The security vulnerabilities are cleared described in the proposal.

> **Does the proposal provide convincing evidence of a robust community of developers and a substantial user base exists?**

Yes. It is obvious that such user base exists for SP-OSE.

> **Does the proposal present clear plans for addressing critical vulnerabilities?**

No. The research plan for addressing the described vulnerabilities requires further explanation.

Does the proposal clearly describe a build and test infrastructure, and procedures to address quality control and security of new content?

No. The proposal does not describe testing or quality control.

Does the proposal contain a detailed and achievable list of milestones?

Yes. A list of milestones is included in the proposal.

Does the proposal present a specific, actionable evaluation plan?

Yes. The proposal describes a good evaluation plan.

Does the proposing team have the required expertise and experience to undertake the activities described in the proposal?

No. While the team has extensive experience in software development and open-source platforms, none of the team members seems to have any experience in security.

Will NSF support serve as the critical catalyst for addressing the identified vulnerabilities (i.e., are there other sources of support that the OSE should be using instead of or in addition to NSF funding)?

Yes. NSF support is critical for open-source ecosystems.

Does the proposal include third-party letters of collaboration attesting to the importance of the vulnerabilities to be addressed from the perspective of users?

Yes. A series of letters are included in the proposal.

Summary Statement
This proposal targets a widely used open-source ecosystem, which has strong impacts in many areas. The security vulnerabilities are important and should be addressed. The proposal would be stronger if the proposed research is described in more detail and the team includes expertise in security.